Online Bookstore — Security & Integration Plan (M4)

Owner: M4 (Security / Integration) **Version:** 1.1 **Inputs:** SRS v1.1 Final, SAD v1.1 **Status:** Final — synchronized

This document covers the security objectives, security controls, security architecture, use-case diagram, integration plan and consistency review for the Online Bookstore. The security objectives and controls were proposed in the first draft of this plan and have since been approved and merged into SRS v1.1 Final (Sections 3.5.1 and 3.5.4); they are reproduced here unchanged. The SRS remains the authority if any wording differs.

Revision	Change
1.0 (draft)	Initial plan against SRS v1.0 Draft and SAD v1.0 Draft; objectives and controls marked [Proposed].
1.1 (Final)	Aligned to SRS v1.1 Final and SAD v1.1: all [Proposed] markers removed; control IDs renamed from SEC-01..20 to SEC-CTRL-01..20 (SEC-01/SEC-02 are the SRS top-level requirements); SEC-CTRL-16 is an optional recommended enhancement; use-case diagram finalized (SRS Figure 1); integration scenario IT-02 corrected; consistency review and decisions updated to resolved.

1. Security Objectives

SO-1 to SO-6 are approved in SRS Section 3.5.1.

ID	Objective	Meaning for this system
SO-1	Confidentiality	A user can see only their own cart, orders and account data. Passwords are never stored in recoverable form.
SO-2	Integrity	Prices, totals, roles, ownership and order state are decided by the server and never trusted from the client. Orders are all-or-nothing.
SO-3	Availability	Misuse such as expensive search requests shall not take the site down; supports the 99% target of NFR-04.
SO-4	Authenticity	Every protected action is tied to a verified, logged-in identity.
SO-5	Authorization	Customers and Sellers can perform only the operations permitted for their role, enforced on the server.
SO-6	Accountability	Failed logins, denied access and failed orders are logged, without secrets, so incidents can be investigated.

2. Security Controls

Top-level SRS requirements: **SEC-01** Role-Based Access and **SEC-02** Protection of User Data. The detailed controls below (SRS 3.5.4, SAD 3.10.2) refine them. Each control is testable, has a stable ID and is verified in STP Section 16.2 under the same ID. SEC-CTRL-16 is optional and outside the mandatory acceptance baseline.

ID	Requirement	Obj.	Parent	Verification
SEC-CTRL-01	Passwords stored only as salted hashes using Django's password hasher.	SO-1	SEC-02	Inspect DB; no plaintext.
SEC-CTRL-02	Password validators enabled: minimum 8 characters, not commonly used, not entirely numeric.	SO-4	SEC-02	Register with weak password → rejected.
SEC-CTRL-03	Login failures show one generic message that does not reveal whether the email exists.	SO-1	SEC-02	Compare unknown-email vs wrong-password responses.

ID	Requirement	Obj.	Parent	Verification
SEC-CTRL-04	Session created only after valid credentials, regenerated at login, destroyed at logout; old session invalid after logout.	SO-4	SEC-02	Session key changes on login; old session invalid after logout.
SEC-CTRL-05	Every protected route requires authentication; anonymous users are redirected to login.	SO-4	SEC-01	Anonymous request to each protected route.
SEC-CTRL-06	Every protected route enforces role on the server (RBAC matrix, §3.3); wrong role → HTTP 403, no data change.	SO-5	SEC-01	Customer hits /books/add/; Seller hits /cart/add/.
SEC-CTRL-07	Role stored server-side, chosen only from the allowed set (Customer, Seller); never from a hidden field or URL; no form makes a user staff/administrator.	SO-5	SEC-01	Tamper with POST data.
SEC-CTRL-08	Cart and order queries scoped to the logged-in user; client-supplied customer IDs ignored; another user's object → HTTP 404.	SO-1	SEC-02	User A requests user B's cart item or order → 404.
SEC-CTRL-09	Prices and totals computed on the server from stored book records; client-submitted prices ignored.	SO-2	SEC-02	POST tampered price → total unchanged.
SEC-CTRL-10	Quantities validated as positive integers not exceeding 10 per cart line.	SO-2	SEC-02	Quantity 0, -1, 11, 99999, "abc".
SEC-CTRL-11	Order creation (Order, Order Items, cart clearing) in one database transaction.	SO-2	SEC-02	Force failure mid-way → no partial order.
SEC-CTRL-12	All state-changing requests use POST with a valid CSRF token.	SO-2	SEC-02	POST without token → 403.
SEC-CTRL-13	User-supplied content (book title, description, search text) output-escaped; no raw HTML.	SO-2	SEC-02	Submit <script> in a listing → shown as text.
SEC-CTRL-14	Database access through the Django ORM only; no SQL built from user input.	SO-2	SEC-02	Code review / grep for raw(and execute(.
SEC-CTRL-15	Search input limited to 100 characters; results paginated at 20 per page.	SO-3	SEC-02	Very long query and large result set.
SEC-CTRL-16	Recommended enhancement (optional): repeated failed logins (e.g. 5 consecutive attempts) may be throttled with a temporary lockout.	SO-3, SO-4	SEC-02	If implemented: script 6 bad logins.
SEC-CTRL-17	Hosted environment: DEBUG=False, HTTPS, secure and HttpOnly cookies, HSTS, secrets from environment variables.	SO-1	SEC-02	Django check --deploy.
SEC-CTRL-18	Logs never contain passwords, session IDs, secret keys or tokens; failed login, denied access and failed order events logged with user ID and timestamp.	SO-6	SEC-02	Log review.
SEC-CTRL-19	Generic error pages; stack traces never exposed.	SO-1	SEC-02	Trigger a 500 and a 404.
SEC-CTRL-20	Post-login next address validated against the application host; external addresses ignored.	SO-4	SEC-02	?next=https://evil.com → ignored.

3. Security Architecture

3.1 Trust boundaries

Step	Zone	Control at the boundary
1	User / Browser (UNTRUSTED)	All input is untrusted.
2	Browser → Views	HTTPS (hosted) + CSRF token on every state-changing request.
3	Views (trusted Django application)	Authentication + role check + validation.
4	Service functions	Cart / order rules; prices, totals and ownership recomputed.
5	Models + ORM → Database	Parameterized queries; database with restricted access.

Principle: everything crossing the browser→server line is untrusted input. Validation and authorization happen at the view layer, and the business rules (prices, totals, ownership) are recomputed in the service layer.

3.2 Defence in depth

Layer	Controls
Presentation	Template auto-escaping, CSRF token in every form, hide irrelevant buttons (UX only, not security).
Request/Access	login_required, a custom role_required("SELLER") / role_required("CUSTOMER") decorator, form validation, safe redirects.
Feature	Ownership filters (filter(customer=request.user)), server-side price lookup, transaction.atomic().
Data	ORM parameterization, DB constraints (FK, NOT NULL, CHECK(quantity > 0), unique (customer, book) on CartItem).
Deployment	HTTPS, env-based secrets, least-privilege DB user, backups, DEBUG=False.

3.3 RBAC matrix (identical to SRS 3.5.5)

Operation (route)	Anonymous Visitor	Customer	Seller
Register	Allowed	Not Allowed	Not Allowed
Login	Allowed	Allowed	Allowed
Logout	Not Allowed	Allowed	Allowed
Browse / Search (/books/, /books/search/)	Allowed	Allowed	Allowed
Add listing (/books/add/)	Login required	403 Denied	Allowed
View cart (/cart/)	Login required	Own cart only	403 Denied
Add / remove cart item	Login required	Own cart only	403 Denied
Place order (/orders/place/)	Login required	Own cart only	403 Denied
View order history (/orders/)	Login required	Own orders only	403 Denied

Every row maps to one view decorator, and one test per denied cell proves the denial (STP Section 16.3).

3.4 Django implementation notes (for the developers)

- **Role storage:** use a custom User with a role field (or a one-to-one Profile); decide before the first migration, since changing it later is painful. The role is set only at registration from {Customer, Seller} (SEC-CTRL-07).
- **Ownership lookup:** get_object_or_404(CartItem, pk=id, customer=request.user). Another user's item then returns 404, so its existence is not leaked.
- **Order placement:** wrap in with transaction.atomic(): read the books inside it, copy the current price into OrderItem.unit_price, then clear the cart.
- **Settings checklist:** AUTH_PASSWORD_VALIDATORS, SESSION_COOKIE_SECURE, CSRF_COOKIE_SECURE, SECURE_SSL_REDIRECT, SECURE_HSTS_SECONDS, ALLOWED_HOSTS, SECRET_KEY from env. Run python manage.py check --deploy before the demo.
- **Throttling (optional, SEC-CTRL-16):** django-axes is the low-effort option.

3.5 Threat review (extends SAD §3.8)

Threat	Example	Control
Brute force / credential stuffing	Script tries many passwords	SEC-CTRL-02 password rules; SEC-CTRL-16 throttling (optional)
Mass assignment / role tampering	Hidden role=admin in registration POST	SEC-CTRL-07 restricted choices, never expose is_staff
Open redirect	/login/?next=//evil.com	SEC-CTRL-20
Session fixation / theft	Reuse of an old session ID	SEC-CTRL-04, SEC-CTRL-17 HttpOnly + Secure cookies
IDOR	/cart/remove/57/ for someone else's item	SEC-CTRL-08
Repudiation	"I never placed that order"	SEC-CTRL-18 logging with user ID and timestamp
Race condition	Two simultaneous order clicks	SEC-CTRL-11 transaction; redirect after POST
Cross-site request forgery	Unwanted state-changing request	SEC-CTRL-12
Injection / unsafe content	Malicious search text or book description	SEC-CTRL-13, SEC-CTRL-14
Denial of service	Expensive search spam	SEC-CTRL-15
Privilege escalation	Customer calls the seller-only route	SEC-CTRL-05, SEC-CTRL-06

4. Use-Case Diagram

The approved UML use-case diagram is SRS Figure 1, reproduced below; it is also reproduced in SAD Section 3.11. Every use case maps to one SRS functional requirement (SRS Table 3). The earlier draft note asking for a redraw is closed.

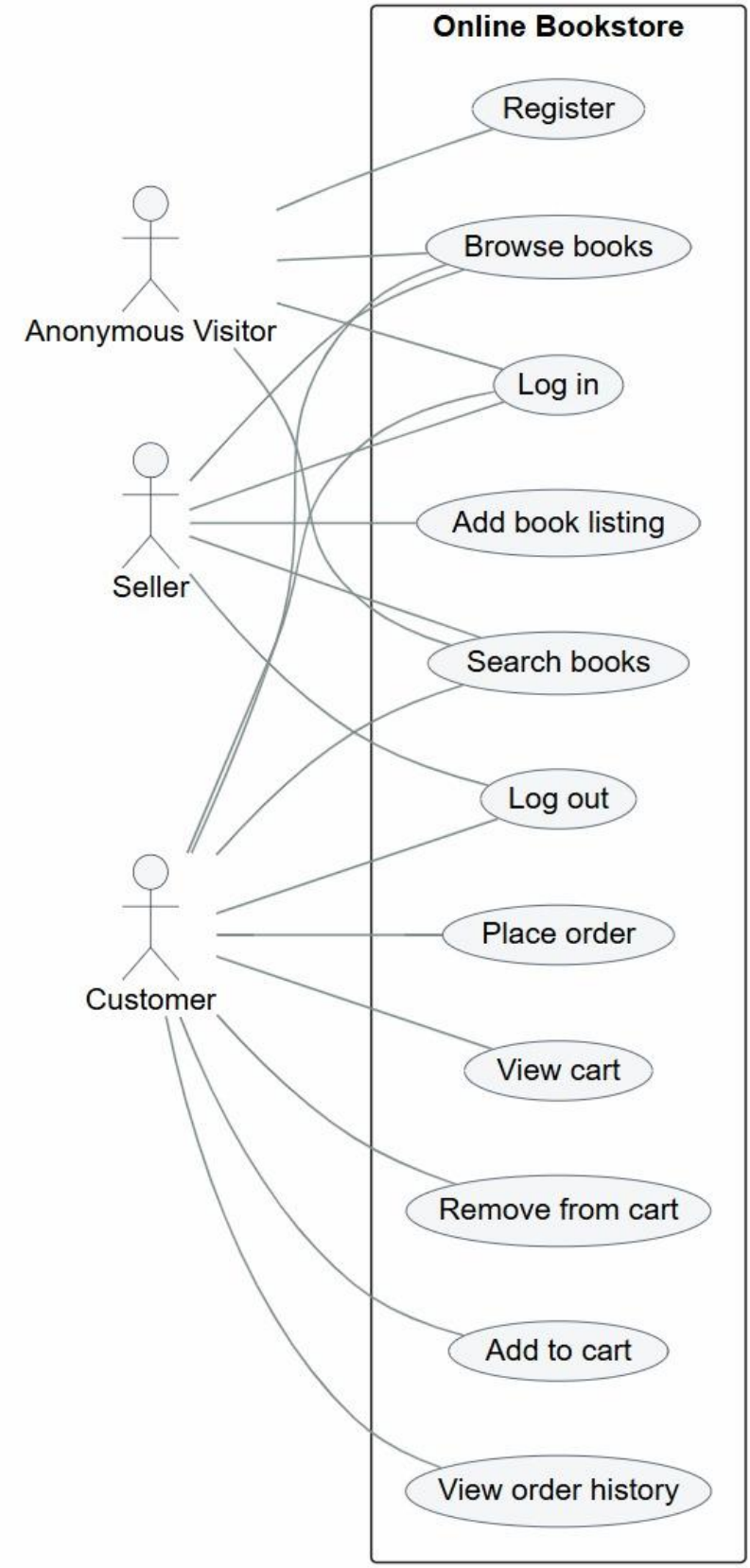


Figure 1. Online Bookstore use-case diagram (identical to SRS Figure 1).

Optional UML refinements for the presentation (not part of the SRS baseline): Place order «include» Validate cart and Calculate total; Add to cart, Place order and View order history «include» Authenticate. Because a Seller cannot purchase (BR-03), Customer and Seller remain separate registered roles.

5. Integration Plan

"Integration" here means the four feature modules (accounts, books, cart, orders) work together without breaking each other's rules.

5.1 Module contracts

Boundary	Contract
accounts → all	Exposes request.user and user.role, plus the role_required decorator. Nobody else reads roles by their own method.
books → cart	cart references Book by FK only. It validates existence via the ORM and never copies the price into the cart.
cart → orders	orders.place_order(user) reads the user's cart through a single function (e.g. cart.services.get_cart_items(user)) and clears it on success.
orders → books	Reads the current price and copies it into OrderItem.unit_price at purchase time.
All → templates	Shared base template (navigation, messages, error pages).

5.2 Integration order (build and test in this sequence)

1. **accounts:** register, login, logout, role stored. Test SEC-CTRL-01 to SEC-CTRL-07.
2. **books:** browse, search, seller add. Test the role gate on /books/add/.
3. **cart:** add, remove, view. Test ownership and validation (SEC-CTRL-08, SEC-CTRL-10).
4. **orders:** place order, history. Test transaction and totals (SEC-CTRL-09, SEC-CTRL-11).
5. **End-to-end:** Seller lists a book, Customer finds it, adds it, orders it and sees it in history. Then run every denied cell of the RBAC matrix.

5.3 Integration test scenarios (identical to STP 16.4 and SAD 4.6)

#	Scenario	Expected
IT-01	Seller adds a book, then a Customer searches for it.	Book appears with the correct price.
IT-02	A Customer adds a book to the cart; the stored price of that book is then changed through a maintenance or test-data update (Sellers cannot edit listings in this version); the Customer places the order.	The order uses the current stored price (server-side).
IT-03	Customer places an order, then views history.	Order and items appear, and the cart is empty.
IT-04	A failure is forced inside order creation.	No Order, no OrderItems, and the cart is intact.
IT-05	User A tries to remove or view user B's cart item or order.	404, no data change.
IT-06	Session expires mid-checkout.	Redirect to login, no partial order.

6. Final Consistency Review

Cross-check of SRS v1.1 Final ↔ SAD v1.1 ↔ STP v1.1 ↔ this plan ↔ diagrams.

6.1 Issues from the first review — all closed

#	Issue (first review)	Resolution
1	No data model section in the SAD.	Closed: SAD 3.6 with ER diagram identical to SRS Figure 2.

#	Issue (first review)	Resolution
2	Naming mismatch (Book Management vs Book Catalogue; Authentication vs Accounts / Authentication).	Closed: “Book Management” and “Accounts / Authentication” used everywhere.
3	Numbered lists continued across sections.	Closed: lists restart in SAD and STP.
4	Figure showing confirmation arrow from Models directly to Browser.	Closed: sequence figures route confirmation through the View.
5	SAD 2.1 referred to a testing section that does not exist.	Closed: SAD 2.1 points to the STP and SAD 3.9.
6	Security objectives TBD in the SRS.	Closed: SO-1 to SO-6 in SRS 3.5.1.
7	No logout route in the API table.	Closed: /logout/ in SAD 4.3; FR-AUTH-03.
8	Seller purchasing not stated.	Closed: BR-03 and RBAC matrix.
9	Book did not record its seller.	Closed: seller_id in the data model; FR-BOOK-03(b).
10	Traceability used requirement areas, not IDs.	Closed: SAD 3.9 and SRS Appendix C use FR/NFR/SEC IDs and TC/IT IDs.
11	Use-case diagram pending.	Closed: SRS Figure 1 is the approved diagram.

6.2 Additional inconsistencies found and corrected in this pass

#	Issue	Fix
12	This plan used SEC-01..20, colliding with SRS SEC-01/SEC-02; the STP used PSC-01..19 (no throttling entry) while the SRS says controls are verified in STP 16.2 under the same ID.	All documents use SEC-CTRL-01..20; STP 16.2 now lists all 20.
13	SAD traceability used TC-AUTH-01 style IDs; the STP and SRS use TC-01..27.	SAD 3.9 uses TC-01..27.
14	STP lacked TC-25, TC-26, TC-27 that SRS Appendix C references; FR-AUTH-03 and FR-CART-03 missing from SAD and STP traceability.	Added to STP 13 and to the SAD and STP matrices.
15	IT-02 (SAD, STP, this plan) had a Seller changing a price, but editing listings is out of scope.	Reworded to a maintenance/test-data price change in all three.
16	Stale statuses: SAD/STP/plan cited SRS v1.0 Draft, listed objectives as proposed/TBD and role selection as open.	Updated to SRS v1.1 Final; decisions recorded as resolved.
17	SEC-CTRL-16 was both “requirement” and “if schedule permits”.	Defined as optional recommended enhancement in SRS 3.5.4 and all documents.
18	SAD data model and several SAD/plan/STP statements said Book has no seller FK.	Updated to SRS Figure 2 and FR-BOOK-03(b).
19	STP Appendix A embedded SAD v1.0 draft pages labelled as the SRS.	Removed.
20	SRS Appendix D cited section 2.3 for the database decision.	Corrected to 2.1, 2.4, 3.1.2.
21	SAD 2.2 said the use-case diagram was in 4.7, where it was not.	Diagram added in SAD 3.11.

6.3 Final consistency checklist

Check	Status
Every SRS requirement appears in the SAD traceability matrix and has at least one test case ID.	Done
Every route in SAD 4.3 appears in the RBAC matrix, the use-case table and at least one test.	Done
Every use case in the diagram maps to an SRS functional requirement.	Done

Check	Status
Role names are identical everywhere (Anonymous Visitor, Customer, Seller).	Done
Component names are identical in diagrams, tables and code module names.	Done
No “Proposed” or TBD item remains except the open deployment environment.	Done
The final code matches the documents (routes, models, permission checks).	Pending – after implementation

7. Decisions

All decisions below are resolved in SRS v1.1 Final (Appendix D).

Decision	Resolution	Why
Role at registration	User picks Customer or Seller; the server validates it; not changeable afterwards. Admin is created only via createsuperuser.	Simple; prevents self-escalation.
Can a Seller also buy?	No, in this version (BR-03).	The SRS describes two distinct roles.
Database	SQLite for development and demonstration, PostgreSQL if hosted.	The ORM keeps the code portable.
Login throttling	SEC-CTRL-16 optional (django-axes if time allows); outside the mandatory baseline.	Cheap, defends against a common attack.
Duplicate add-to-cart	Increase the quantity on the existing line, unique (customer, book), maximum 10.	Easier to test; the database enforces it.
Open: deployment environment	Choose local demonstration, managed hosting, VPS/cloud VM or containerized deployment.	Does not affect any requirement.

8. Deliverables Checklist (M4)

Deliverable	Status
Security objectives → merged into SRS 3.5.1	Done
Security controls with IDs → SRS 3.5.4, STP 16.2	Done
Security architecture section → SAD 3.10	Done
Final use-case diagram → SRS Figure 1, SAD 3.11	Done
Integration order and test scenarios → STP 16.4	Done
Consistency issues resolved in all documents (Section 6)	Done
Team review of the final set	Pending